SOC INCIDENT INVESTIGATION REPORT

The Golden Invoice

Phishing Email Investigation & Response

Brackenmoor NHS Foundation Trust • Digital Security Team

REPORT ID	INCIDENT DATE	STATUS	TLP CLASSIFICATION
INC-20260810-0143	25 August 2026	Closed – Contained	TLP:AMBER

Prepared by

SOC Analyst, Ioan Miller

Distribution

Brackenmoor NHS Foundation Trust Digital Security Team

Internal / training use only

In This Report

Executive Summary
Stakeholder Summary
1. Incident Classification
2. Detection and alert details
3. Incident Timeline
4. Technical Analysis
5. Indicators of Compromise
6. MITRE ATT&CK Mapping
7. Impact & Scope Assessment
8. Risk Assessment
9. Response & Containment Actions
10. Recommendations
11. Lessons Learned

Executive Summary

SEVERITY: MEDIUM	STATUS: CLOSED	CONFIRMED PHISHING	NO COMPROMISE

On 25 August 2026, the SOC examined an invoice-themed message reported by the Accounts Payable team. Analysis of the message headers and HTML content identified several indicators of phishing, including an unauthorised sending server, no DKIM signature, an invalid DMARC result and a Reply-To address hosted on Gmail. The “View Invoice” button also concealed a destination unrelated to the claimed sender.Gateway checks found no additional recipients and no evidence that the original recipient followed the link or disclosed credentials. The identified sender and URL artefacts were added to the simulated email controls. The incident was assessed as Medium severity and closed at Trust level with Low residual risk.

1	0	0	~1h 03
RECIPIENT AFFECTED	CREDENTIALS LOST	SYSTEMS IMPACTED	TIME TO CLOSURE

Stakeholder Summary

On 25 August 2026, the Digital Security Team investigated a fraudulent invoice email recovered by the Accounts Payable mailbox. The impersonal an invoicing provider and attempted to direct the recipients to a suspected credential harvesting website.

The recipient recognised the email as suspicious and reported it before integrating with the embedded link, the investigation found no evidence that credentials were submitted. A search of the email environment did not find any recipients affected by the campaign.

The incident was classified as Medium due to the email targeting a finance related function and could have led to account compromise if successful.

1. Incident Classification

Report ID	INC-20260810-0143
Case Name	The Golden Invoice
Incident Category	Phishing – Credential Harvesting (Spearphishing Link)
MITRE ATT&CK Technique	T1566.002 – Phishing: Spearphishing Link
Reporting Source	User-reported (Accounts Payable, one-click phishing button)

Affected Organisation	Brackenmoor NHS Foundation Trust
Severity	Medium (see Section 8, Risk Assessment)
Status	Closed – Contained at Triage
CSOC Escalation	Not required – escalation criteria not met (see Section 8)

2. Detection and alert details

Field	Value
Alert ID	ALT-2026-01872
Detection source	Email security gateway / user phishing report
Detection rule	Suspected credential-harvesting email
Initial severity	Critical
Final incident severity	Medium
Initial risk score	96
Assigned analyst	Ioan Miller
First observed	25 August 2026, 20:57 BST
Investigation confidence	High

3. Incident Timeline

All times shown are local (BST, UTC+1) on Tuesday, 25 August 2026. All investigative and containment activity was completed during the same SOC shift, with no evidence of exposure continuing into a later monitoring period.

Time	Phase	Event
20:57	**Delivery**	Phishing email was delivered to the email address - accountspayable@brackenmoor.nhs.uk
21:00	**Report Intake**	The recipient reported the email using the Trust's one-click phishing button.
21:02	**Triage Start**	The ticket was auto-created " INC-20260810-0143" and assigned to the queue.
21:05	**Preservation**	Checked dashboard to analyze the Alert ID - ALT-2026-01872 on the Alerts tab , Source IP 203.0.113.77, MITRE ATT&CK T1586.002. Description : Credential-harvesting phishing attempt reported by Accounts Payable. SPF failed, DKIM was absent and DMARC returned perm error.
21:12	**Header Forensics**	Reviewed the header using Mxtoolbox and confirmed three principal authentication

Time	Phase	Event
		controls failed - SPF:Fail was not authorised to send email for payhub-notify-secure.com. DKIM: None - The message had no DKIM signature and sender and content could not be verified. DMARC: Permanent error - No valid DMARC record was found for the sender's domain.
21:18	**Traced IP**	Used virusTotal to trace the IP address and found the IP address originated from Asia. Communicating Files flagged Ransomware called "program__ransomware_insert_threshold".
21:20	**URL Triage**	Recovered the destination URL from the email HTML and assessed it using isolated analysis tools.
21:24	**Content Analysis**	Recorded the urgency, payment pressure, sender impersonation and lack of personalisation used in the message.
21:25	**IOC Extraction**	Created an indicator set containing the claimed sender domain, observed IP address, Reply-To address and phishing URL.
21:27	**Scope & Correlation**	Queried gateway records for matching sender, subject and URL activity across other mailboxes.
21:29	**Correlation Complete**	The search returned no additional deliveries and no evidence of URL interaction.
21:30	**Verdict**	Analyst verdict recorded as a confirmed credential-harvesting phishing message.
21:47	**Escalation Check**	Compared the findings against the escalation policy and determined that Trust-level handling was sufficient.
21:53	**Containment**	Added the sender and URL artefacts to the simulated gateway-blocking controls.
21:58	**Documentation**	Completed the case record and attached the investigation evidence.
22:00	**Closure**	Closed the incident after confirming containment and the absence of user impact.

3.1 Evidence and Data Source Reviewed

Evidence ID	Evidence	Source	Purpose
E-01	Original phishing email .eml	Recipient mailbox	Preserve complete message and HTML body
E-02	Full email headers	Email gateway	Analyse delivery route and authentication
E-03	SOC alert ALT-2026-01872	SOC dashboard	Record original detection and risk score

E-04	Gateway recipient search	Email gateway	Identify additional recipients
E-05	MXToolbox results	Isolated analysis browser	Confirm header parsing and authentication results
E-06	Extracted phishing URL	Email HTML source	Identify the deceptive destination safely

All analysis was conducted using preserved evidence and isolated tools. The embedded URL was extracted without being opened on a production device.

4. Technical Analysis

4.1 Email Metadata

From (display)	“PayHub Invoicing” <no-reply@payhub-notify-secure.com>
Reply-To	Billing Support <payhub.billingsupp0rt@gmail.com>
To	accountspayable@brackenmoor.nhs.uk
Subject	Invoice INV-33421 Shared With You – Payment Overdue, Action Required
Date	Mon, 10 Aug 2026 09:18:00 +0100
Message-ID	<a17f4c02-9be3-4a11-8fce-1d2b6e5a7f90@MW4NAM10FT021…prod.protection.outlook.com>

4.2 Sender Authentication Analysis

Analysis of the message produced the following technical artefacts. They were documented for correlation and simulated containment. Values marked as contextual or reserved for documentation should not be applied directly to production blocking controls.

SPF returned a failure, no DKIM signature was present and DMARC produced a permanent error because the domain had no valid policy record. When considered alongside the sender and Reply-To mismatch, these results strongly supported the phishing verdict.

Check	Result	Detail
SPF	FAIL	Domain payhub-notify-secure.com does not authorise 203.0.113.77 to send on its behalf
DKIM	NONE	No DKIM signature present on the message
DMARC	PERMERROR	No valid DMARC policy record published for the sending domain

4.3 Header & Infrastructure Analysis

The Received chain was examined from bottom to top, beginning with the earliest recorded hop. The earliest observed entry identifies vqztrmhloknp.cn using 203.0.113.77, which submitted the message to mail.payhub-notify-secure.com. The message then passed through Microsoft Exchange Online Protection infrastructure in the NAM10 and EUR02 regions before reaching the Trust’s mail gateway.

The claimed sending domain did not authorise 203.0.113.77 through SPF. The message also contained no DKIM signature and no valid DMARC record was available. These authentication results mean the claimed sender identity could not be verified. MXToolbox reported a total delivery delay of approximately 285 seconds.

4.4 URL & Link Analysis

The HTML body displayed a “View Invoice” button, but the underlying destination was hxxps://invoice-review[.]link/inv/33421-settle. This domain did not match the claimed sending domain, payhub-notify-secure.com, or the Gmail Reply-To address. The discrepancy between the displayed button and its destination is consistent with a deceptive phishing link. The URL was extracted from the message source without being opened on a production device.

Attribute	Value
Displayed anchor text	View Invoice
True link domain (defanged)	hxxps://invoice-review[.]link/inv/33421-settle
Domain age / reputation	Does not match the displayed sender or Reply-To domain
Handling	Link extracted without opening it on a production device

4.5 Content & Social-Engineering Analysis

- Urgency and fear: A 24-hour deadline and threat of “service interruption” encouraged the recipient to act without completing normal verification.
- Lack of personalisation: The message did not name a specific recipient or reference a verifiable purchase order, supplier contact or previous invoice.
- Brand impersonation: The sender presented the message as originating from “PayHub Invoicing”, although the sender’s identity could not be authenticated.
- Reply To mismatch: Replies were redirected from the claimed corporate sender domain to payhub.billingsupp0rt@gmail.com, a free webmail address containing the suspicious spelling supp0rt.
- Financial pretext: The message claimed that an invoice for £4,860 was overdue and specifically targeted an Accounts Payable mailbox.
- Outcome: No evidence showed that the recipient opened the link or submitted credentials.

4.6 Attachment Analysis

The email contained no file attachments. The suspected phishing mechanism was an embedded hyperlink rather than an attached document or executable. Attachment analysis was therefore considered but determined not to be applicable.

4.7 Tracking Mechanism

The HTML body contained an invisibly styled 1×1-pixel image hosted on the claimed sender’s domain. If the recipient’s email client loaded this remote image, it could notify the sender that the message had been opened and that the mailbox was active. However, the presence of the tracking pixel alone does not prove that it was successfully loaded.

5. Indicators of Compromise

The following indicators were extracted during the investigation and submitted to the email gateway blocklist. They are provided here in a format suitable for direct ingestion into a SIEM, threat intelligence platform, or MISP event.

Type	Indicator	Context
Domain	payhub-notify-secure.com	Spoofed sending domain; SPF fail, DKIM none, DMARC permerror
IP Address	203.0.113.77	Relay / originating IP (RFC 5737 documentation range for this exercise)
Hostname	vqztrmhloknp.cn	True originating host in the Received chain
Domain	gmail.com	Reply-To redirect target (free webmail, context indicator only)
Domain (defanged)	invoice-review[.]link	True destination of the “View Invoice” link
Email Address	no-reply@payhub-notify-secure.com	Spoofed From address
Email Address	payhub.billingsupp0rt@gmail.com	Reply-To address

6. MITRE ATT&CK Mapping

No attachments were present in the preserved message. The attempted delivery method relied on an HTML hyperlink, so the investigation focused on the URL and message content rather than file analysis.

Tactic	Technique ID	Technique Name	Observed Evidence
Initial Access	T1566.002	Phishing: Spearphishing Link	Invoice email with a link to a credential-harvesting page
Defense Evasion	T1036	Masquerading	Payhub name and brand impersonation of a plausible invoicing platform

Reference: MITRE ATT&CK Enterprise Matrix, technique T1566.002 (attack.mitre.org/techniques/T1566/002).

7. Impact & Scope Assessment

Inspection of the HTML identified a hidden 1×1-pixel remote image. If loaded by the recipient's email client, the request could provide the sender with evidence that the mailbox was active and that the message had been viewed. No evidence was available to confirm that the image was successfully retrieved.

Question	Finding
Recipients identified	1 (Accounts Payable coordinator)
Other recipients (gateway sweep)	None identified for this campaign
Link clicked / visited by user	No
Credentials submitted	No
Data exfiltrated	No evidence of data exfiltration identified
Systems or accounts affected	No systems or accounts confirmed as affected
Financial loss	None
Potential impact had it succeeded	Credential compromise of an Accounts Payable account; possible follow-on business email compromise or fraudulent payment redirection

8. Risk Assessment

Potential impact was assessed as Medium–High because access to a finance-related mailbox could support payment fraud, supplier impersonation or further compromise of internal and external contacts.

MED-HIGH	MED-HIGH	MEDIUM	LOW
PRE-CONTAINMENT LIKELIHOOD	POTENTIAL IMPACT	OVERALL SEVERITY	RESIDUAL RISK

Likelihood is rated medium-high because the email used a plausible pretext, correctly targeted an Accounts Payable function, and showed no unusual technical sophistication that would flag it to an untrained recipient. Impact is rated medium-high because a successful credential harvest against a finance-adjacent account carries realistic potential for business email compromise or fraudulent payment redirection. The overall severity of Medium reflects the plausible financial impact, balanced against the fact that this was a single-recipient, role-targeted but technically unsophisticated phishing attempt that was reported before any user interaction occurred.

9. Response & Containment Actions

Time	Action	Outcome
21:53	**Added the suspicious sender and URL artefacts to the simulated email-security controls.**	Future messages matching the selected artefacts should be rejected or quarantined.
21:55	**Completed an organisation-wide gateway search for related deliveries.**	No additional recipients or affected accounts required containment.
21:57	**Compared the confirmed findings with the established CSOC escalation conditions.**	The incident remained within the Trust's local response threshold.
22:00	**Finalised the incident record with supporting evidence and the extracted indicator list.**	Retained the case record for auditing and comparison with future campaigns.

The investigation found no credential disclosure, account takeover, system compromise or wider campaign activity within the Trust. The message targeted an Accounts Payable function, it contained no evidence of insider knowledge or organisation-specific preparation.

10. Recommendations

Immediate

- Use the incident as an anonymised case during the next finance-team security briefing.
- Test the newly introduced mail controls and confirm that matching events appear correctly in monitoring logs.

Strategic

- Require payment-detail changes to be confirmed through a trusted contact method of the original email.
- Create or refine a detection rule for finance-related messages where the From and Reply-To domains do not match.
- Review the email gateway's handling of external messages that fail SPF, contain no DKIM signature or cannot pass DMARC evaluation.
- Confirm that Trust-owned domains publish appropriate SPF, DKIM and DMARC records to reduce the risk of the Trust's own identity being spoofed.
- Submit validated and appropriate indicators through the organisation's approved threat-intelligence process.

11. Lessons Learned

What worked well

- Prompt reporting by the recipient prevented the message from progressing into credential theft or account compromise.
- Following a consistent investigation process enabled the analyst to preserve the original message, validate the key indicators and reach a documented conclusion.

Detection gap identified

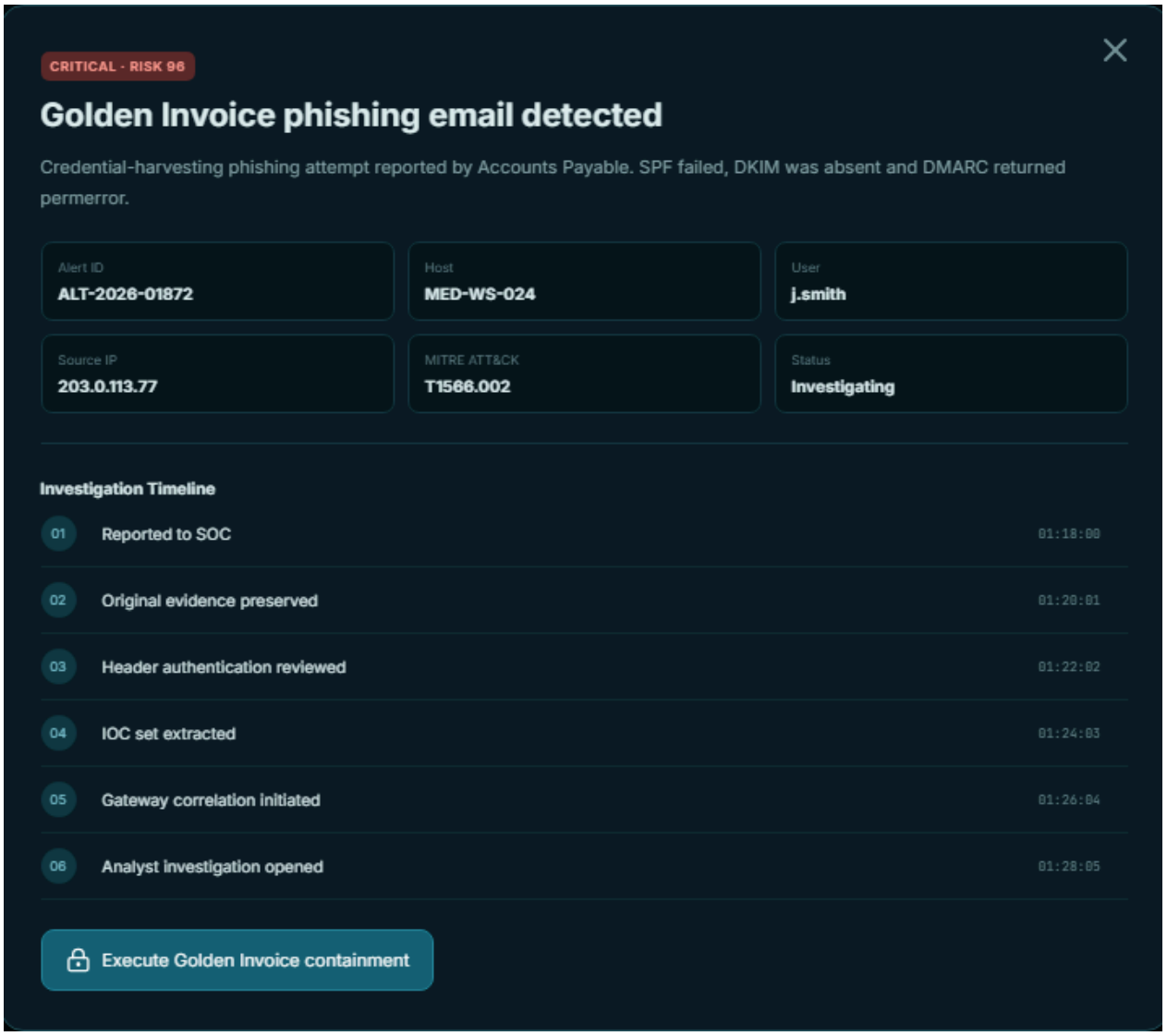
- The difference between the From and Reply-To domains was not raised automatically. A new detection condition should therefore be considered for financial messages displaying this pattern.

Appendix A: Full Email Headers

```
Reproduced from the preserved original .eml (phishing_sample_goldeninvoice_nhs_v1.eml). Provided for audit and
re-analysis.
Return-Path: <no-reply@payhub-notify-secure.com>
Received: from DB3EUR02HT219.eop-EUR02.prod.protection.outlook.com (unknown [203.0.113.15])
       by mail.pot (Postfix) with ESMTP id 4C29A17B53
       for <accountspayable@brackenmoor.nhs.uk>; Mon, 10 Aug 2026 09:18:47 +0100 (BST)
Received: from MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com (unknown [40.93.15.201])
       by DB3EUR02HT219.eop-EUR02.prod.protection.outlook.com with ESMTP id 8CE21FA400
       for <accountspayable@brackenmoor.nhs.uk>; Mon, 10 Aug 2026 10:17:59 +0200 (CEST)
Received: from mail.payhub-notify-secure.com (mail.payhub-notify-secure.com [203.0.113.77])
       by MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com with ESMTP id 6D42AF19
       for <accountspayable@brackenmoor.nhs.uk>; Mon, 10 Aug 2026 09:15:31 +0100 (BST)
Received: from vqztrmhloknp.cn (unknown [203.0.113.77])
       by mail.payhub-notify-secure.com (Postfix) with ESMTPA id 2FA5C18E6
       for <accountspayable@brackenmoor.nhs.uk>; Mon, 10 Aug 2026 10:14:02 +0200 (CEST)
Authentication-Results: mail.pot;
       spf=fail (mail.pot: domain of payhub-notify-secure.com does not designate 203.0.113.77 as permitted
sender) smtp.mailfrom=no-reply@payhub-notify-secure.com;
       dkim=none (no signature);
       dmarc=permerror (no valid record) header.from=payhub-notify-secure.com
Received-SPF: Fail (mail.pot: domain of payhub-notify-secure.com does not designate 203.0.113.77 as permitted
sender) client-ip=203.0.113.77; envelope-from=no-reply@payhub-notify-secure.com;
helo=mail.payhub-notify-secure.com;
X-MS-Exchange-Organization-AuthAs: Anonymous
X-MS-Exchange-Organization-AuthSource: MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com
Message-ID:
<a17f4c02-9be3-4a11-8fce-1d2b6e5a7f90@MW4NAM10FT021.eop-MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com>
From: "PayHub Invoicing" <no-reply@payhub-notify-secure.com>
Reply-To: Billing Support <payhub.billingsupp0rt@gmail.com>
To: accountspayable@brackenmoor.nhs.uk
Subject: Invoice INV-33421 Shared With You - Payment Overdue, Action Required
Date: Mon, 10 Aug 2026 09:18:00 +0100
MIME-Version: 1.0
Content-Type: text/html; charset=UTF-8
Content-Transfer-Encoding: 7bit
```

```
<html>
  <body>
    <p><strong>An invoice has been shared with you and is now overdue.</strong></p>
    <p>Invoice details:</p>
    <ul>
      <li><strong>Invoice number:</strong> INV-33421</li>
      <li><strong>Amount due:</strong> &pound;4,860.00</li>
      <li><strong>Original due date:</strong> Aug 03, 2026</li>
      <li><strong>Status:</strong> Overdue (7 days)</li>
      <li><strong>Billed to:</strong> Brackenmoor NHS Foundation Trust, Accounts Payable</li>
    </ul>
    <p>To avoid a service interruption on your supplier account, please review and settle this invoice within 24
hours.</p>
    <!-- Displayed button text ("View Invoice") did not match the link destination shown on hover (defanged for
safety in this dataset) -->
    <!-- Original href: hxxps://invoice-review[.]link/inv/33421-settle -->
    <p><a href="http://example.invalid/invoice/view?id=INV-33421">View Invoice</a></p>
    <p>Thank you for your continued business.<br>PayHub Invoicing Services</p>
    <!-- Tracking pixel (defanged for safety in this dataset) -->
    <!-- Original: <img src="http://payhub-notify-secure.com/px/a88213HqLPd47720KzWnq11305RvTf22841mBcS93140" width="1"
height="1" style="visibility:hidden"> -->
    <img src="http://example.invalid/px/a88213HqLPd47720KzWnq11305RvTf22841mBcS93140" width="1" height="1"
style="visibility:hidden" alt="">
  </body>
</html>
```

Appendix B: SOC Dashboard



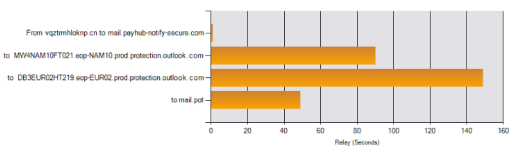
Appendix C : Email Header analysis using mxtoolbox

Delivery Information

- DMARC Compliant (No DMARC Record Found)
  - SPF Alignment
  - SPF Authenticated
  - DKIM Alignment
  - DKIM Authenticated

Relay Information

Received Delay:	285 seconds



Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	vqztrmhloknp.cn 203.0.113.77	mail.payhub-notify-secure.com	ESMTPA	8/10/2026 8:14:02 AM	✓
2	1 minutes	mail.payhub-notify-secure.com 203.0.113.77	MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com	ESMTP	8/10/2026 8:15:31 AM	✓
3	2 minutes	MW4NAM10FT021.eop-NAM10.prod.protection.outlook.com 40.93.15.201	DB3EUR02HT219.eop-EUR02.prod.protection.outlook.com	ESMTP	8/10/2026 8:17:59 AM	✓
4	48 seconds	DB3EUR02HT219.eop-EUR02.prod.protection.outlook.com 203.0.113.15	mail.pot	ESMTP	8/10/2026 8:18:47 AM	✓

Appendix D : Virustotal : Communicating Files

Communicating Files (2)

Scanned	Detections	Type	Name
2025-08-03	46 / 71	Win32 EXE	program__ransomware_insert_threshold_...
2018-03-19	4 / 59	Network capture	nsm01.pcap